CYBERSECURITY STUDY NOTES - COMPLETE GUIDE

TABLE OF CONTENTS

NOTE 1 : Cybersecurity GRC (Governance, Risk and Compliance)
NOTE 2 : Penetration Testing
NOTE 3 : VAPT (Vulnerability Assessment and Penetration Testing)
NOTE 4 : Ethical Hacking
NOTE 5 : Network Security
NOTE 6 : Vulnerabilities
NOTE 7 : Software Security Issues
NOTE 8 : Cryptography
NOTE 9 : Network Attacks
NOTE 10 : Incident Response and Digital Forensics
NOTE 11 : Malware Analysis
NOTE 12 : Cloud Security and Social Engineering

Each note contains: introduction, core concepts, frameworks/tools, processes, examples, best practices, career notes, common interview questions and a summary.

NOTE: These notes are for education and for authorised, legal security work only. Never test systems you do not own or have written permission to test.

NOTE 1: CYBERSECURITY GRC (GOVERNANCE, RISK AND COMPLIANCE)

1.1 INTRODUCTION

GRC stands for Governance, Risk management and Compliance. It is the discipline that makes sure an organisation's security efforts are aligned with business goals, that risks are understood and managed, and that legal, regulatory and contractual obligations are met.

While penetration testers and SOC analysts work "hands-on" with technology, GRC professionals work with policies, frameworks, people, audits and decisions. A GRC analyst answers questions such as:

- What are the most important assets we must protect?
- What could go wrong, how likely is it and how bad would it be?
- Which laws, standards and contracts apply to us?
- Are our controls working and can we prove it to an auditor?
- Who is accountable when something fails?

GRC is one of the fastest-growing and most accessible entry points in cybersecurity because it needs communication, analysis and business sense in addition to technical understanding.

1.2 THE THREE PILLARS

A) GOVERNANCE

Governance is the system by which an organisation directs and controls its security. It defines who makes decisions, who is accountable and how security supports the business.

Key elements:
- Board and executive oversight (e.g. a security steering committee)
- Roles: CISO, CIO, Data Protection Officer (DPO), risk owners, asset owners
- Security strategy and roadmap tied to business objectives
- Policy hierarchy (see 1.4)
- Security metrics and reporting (KPIs/KRIs)
- Budget and resource allocation
- Security culture and awareness

B) RISK MANAGEMENT

Risk management is the process of identifying, analysing, evaluating, treating and monitoring risks to an acceptable level.

C) COMPLIANCE

Compliance means adhering to laws, regulations, standards, contracts and internal policies. It includes evidence collection, audits, gap analysis and remediation tracking.

An important idea: COMPLIANCE IS NOT THE SAME AS SECURITY. An organisation can pass an audit and still be breached. Compliance sets a minimum baseline; good security goes beyond it.

1.3 KEY TERMINOLOGY

```
Asset        : Anything of value (data, systems, people, reputation).
Threat       : A potential cause of an unwanted incident (hacker, malware,
               natural disaster, insider, human error).
Vulnerability: A weakness that a threat can exploit.
Risk         : The potential for loss when a threat exploits a vulnerability.
               Often expressed as Risk = Likelihood x Impact.
Control      : A safeguard that reduces risk (also called countermeasure).
```

```
Inherent risk: Risk before any controls are applied.
Residual risk: Risk remaining after controls are applied.
Risk appetite: The amount/type of risk an organisation is willing to pursue.
Risk tolerance: The acceptable deviation around the risk appetite.
Risk owner   : The person accountable for a specific risk.
Exposure     : The state of being open to loss from a threat.
Control gap  : Difference between required and actual control state.
Audit finding: A documented deviation from a requirement.
Evidence     : Proof (logs, screenshots, configurations, records) that a
               control exists and works.

The CIA Triad underpins everything:
  Confidentiality - only authorised people can access information.
  Integrity       - information is accurate and unaltered.
  Availability    - information and systems are accessible when needed.
Extended models add: Authenticity, Non-repudiation, Accountability and Privacy.
```

1.4 THE POLICY HIERARCHY

```
1. POLICY      - High-level statement of management intent. Mandatory.
                   Example: "All sensitive data must be encrypted."
2. STANDARD    - Specific mandatory requirements supporting a policy.
                   Example: "AES-256 for data at rest; TLS 1.2+ in transit."
3. PROCEDURE   - Step-by-step instructions to carry out a task.
                   Example: "How to provision an encrypted laptop."
4. GUIDELINE   - Recommended, non-mandatory advice.
5. BASELINE    - Minimum security configuration (e.g. CIS benchmark level).

Common security policies: Information Security Policy, Acceptable Use Policy,
Access Control Policy, Password Policy, Data Classification Policy, Incident
Response Policy, Business Continuity Policy, Remote Work Policy, Vendor
Management Policy, Backup Policy, Change Management Policy, BYOD Policy.

Policy lifecycle: Draft -> Review -> Approve -> Publish -> Train -> Enforce ->
Monitor -> Review annually (or after major change).
```

1.5 RISK MANAGEMENT PROCESS (IN DETAIL)

```
STEP 1 - ESTABLISH CONTEXT
   Define scope, objectives, stakeholders, risk criteria, risk appetite and
   methodology (qualitative, quantitative or hybrid).

STEP 2 - RISK IDENTIFICATION
   Find what could go wrong. Methods:
   - Asset inventory and data-flow mapping
   - Threat modelling (STRIDE, attack trees)
   - Workshops and interviews
   - Vulnerability scans and pen test reports
   - Incident history and threat intelligence
   - Audit findings, vendor assessments
   Output: Risk register entries (risk statement, asset, threat,
   vulnerability, owner).

   Good risk statement format:
   "Due to [cause/vulnerability], [threat event] may occur, resulting in
   [impact] to [asset/objective]."
   Example: "Due to unpatched VPN appliances, an attacker may gain remote access,
   resulting in ransomware and loss of customer-facing services."

STEP 3 - RISK ANALYSIS
   QUALITATIVE: Uses ratings such as Low/Medium/High or 1-5 scales for
   likelihood and impact, plotted on a risk matrix (heat map).

     Impact ->     1 Minor   2 Moderate   3 Major   4 Severe   5 Critical
```

```
   Likelihood
   5 Almost sure     5          10          15          20          25
   4 Likely          4           8          12          16          20
   3 Possible        3           6           9          12          15
   2 Unlikely        2           4           6           8          10
   1 Rare            1           2           3           4           5
```

```
   Typical bands: 1-4 Low, 5-9 Medium, 10-16 High, 17-25 Critical.

   QUANTITATIVE: Uses money and probability.
   - Asset Value (AV)
   - Exposure Factor (EF): % of asset lost in an event
   - Single Loss Expectancy (SLE) = AV x EF
   - Annualised Rate of Occurrence (ARO): expected events per year
   - Annualised Loss Expectancy (ALE) = SLE x ARO

   Worked example:
   Server holds data worth 500,000. A breach would destroy 40% of that value.
   SLE = 500,000 x 0.40 = 200,000.
   Breach expected once every 4 years -> ARO = 0.25.
   ALE = 200,000 x 0.25 = 50,000 per year.
   If a control costs 20,000/year and reduces ALE to 10,000, the benefit is
   40,000 - 20,000 = 20,000 net saving, so the control is justified.

   FAIR (Factor Analysis of Information Risk) is a recognised model for
   quantifying cyber risk in financial terms.

STEP 4 - RISK EVALUATION
   Compare risk levels with risk appetite and decide which risks need
   treatment and in what priority.

STEP 5 - RISK TREATMENT (the "4 Ts")
   1. MITIGATE / REDUCE : Apply controls (patching, MFA, segmentation).
   2. TRANSFER / SHARE  : Cyber insurance, outsourcing, contracts.
   3. AVOID / TERMINATE : Stop the risky activity (discontinue a service).
   4. ACCEPT / TOLERATE : Formally accept the risk with management sign-off.
   Treatment produces a Risk Treatment Plan with owners, deadlines, cost.

STEP 6 - MONITOR AND REVIEW
   Track Key Risk Indicators (KRIs), review the risk register regularly,
   re-assess after incidents, new projects or changes in threat landscape.

STEP 7 - COMMUNICATE AND CONSULT
   Continuous throughout: report to executives, owners and regulators in
   language they understand.
```

1.6 TYPES OF CONTROLS

```
By nature:
  - Administrative (managerial): policies, training, background checks.
  - Technical (logical): firewalls, encryption, MFA, antivirus.
  - Physical: locks, CCTV, badges, fences, guards.

By function:
  - Preventive    : stop an event (access control, firewalls).
  - Detective     : identify an event (IDS, log review, audits).
  - Corrective    : fix after an event (patching, restore from backup).
  - Deterrent     : discourage (warning banners, CCTV signs).
  - Recovery      : restore operations (DR site, backups).
  - Compensating  : alternate control when the primary cannot be applied.
  - Directive     : mandate behaviour (policies).

Defence in depth: layering multiple controls so that failure of one does not
lead to total compromise.
```

1.7 MAJOR FRAMEWORKS AND STANDARDS

ISO/IEC 27001 (ISMS)
- International standard for an Information Security Management System.
- Certifiable. Uses Plan-Do-Check-Act.
- Main clauses 4-10: Context, Leadership, Planning, Support, Operation, Performance evaluation, Improvement.
- Annex A lists controls (2022 version has 93 controls grouped into Organisational, People, Physical, Technological).
- Key documents: Scope, Risk Assessment Method, Statement of Applicability (SoA), Risk Treatment Plan, Internal audit reports, Management review.
- Certification: Stage 1 (documentation review), Stage 2 (implementation audit), then annual surveillance audits and 3-year recertification.

ISO/IEC 27002 : Guidance on implementing Annex A controls.
ISO/IEC 27005 : Information security risk management guidance.
ISO 31000 : General risk management principles.
ISO 22301 : Business continuity management.
ISO/IEC 27701 : Privacy information management extension.

NIST CYBERSECURITY FRAMEWORK (CSF)
- Voluntary framework. Version 2.0 (2024) has six functions: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER.
- Uses Tiers (maturity) and Profiles (current vs target).

NIST SP 800-53 : Catalogue of security and privacy controls (US federal).
NIST SP 800-37 : Risk Management Framework (RMF).
NIST SP 800-30 : Guide for conducting risk assessments.
NIST SP 800-61 : Incident handling guide.
NIST SP 800-171: Protecting Controlled Unclassified Information.

CIS CONTROLS : Prioritised set of 18 safeguards with Implementation Groups (IG1, IG2, IG3). Practical and good for small organisations.

COBIT : IT governance framework from ISACA aligning IT with business goals.

SOC 2 : Attestation report (AICPA) on controls relevant to the Trust Services Criteria: Security, Availability, Processing Integrity, Confidentiality, Privacy. Type I = design at a point in time; Type II = operating effectiveness over a period (usually 6-12 months).

PCI DSS : Payment Card Industry Data Security Standard for organisations that handle cardholder data. 12 high-level requirements covering network security, protecting cardholder data, vulnerability management, access control, monitoring/testing and policy.

HIPAA : US law protecting health information (Privacy, Security, Breach Notification rules).

GDPR : EU General Data Protection Regulation. Principles: lawfulness, fairness, transparency; purpose limitation; data minimisation; accuracy; storage limitation; integrity and confidentiality; accountability. Breach notification to regulator within 72 hours. Fines up to 20 million euros or 4% of global annual turnover, whichever is higher.

INDIA-SPECIFIC
- Information Technology Act, 2000 (and amendments) with CERT-In rules (e.g. reporting certain incidents within 6 hours; log retention of 180 days within India as per CERT-In directions of 2022).
- Digital Personal Data Protection Act, 2023 (DPDP Act): consent-based processing, data principal rights, duties of data fiduciaries, Data Protection Board of India.
- RBI guidelines for banks/NBFCs, SEBI cybersecurity framework for market entities, IRDAI guidelines for insurers.

OTHER
  - NIS2 (EU) for essential/important entities.
  - DORA (EU) for financial sector digital operational resilience.
  - SOX (US) for financial reporting integrity (IT general controls).
  - CCPA/CPRA (California) privacy laws.
  - FedRAMP for US government cloud services.
  - CSA CCM (Cloud Controls Matrix) for cloud environments.

1.8 COMPLIANCE AND AUDIT LIFECYCLE

1. Identify applicable requirements (laws, contracts, standards).
2. Map requirements to controls (a control can satisfy multiple standards;
   "test once, comply many").
3. Perform gap assessment to compare current state with required state.
4. Create remediation plan with owners and timelines.
5. Implement controls and collect evidence.
6. Internal audit / readiness assessment.
7. External audit or certification.
8. Address findings (corrective action plan).
9. Continuous monitoring and annual review.

Types of audits:
  - Internal audit (first party)
  - Customer/supplier audit (second party)
  - Independent/certification audit (third party)

Audit evidence types: observation, inspection of documents, inquiry
(interviews), re-performance, and system-generated reports.

Audit finding classification: Major non-conformity, Minor non-conformity,
Observation/Opportunity for improvement.

Auditor mindset: "If it isn't documented and evidenced, it didn't happen."

1.9 THIRD-PARTY / VENDOR RISK MANAGEMENT (TPRM)

Most modern breaches involve suppliers (e.g. supply chain attacks).
Lifecycle:
  1. Vendor identification and tiering (critical, high, medium, low).
  2. Due diligence: security questionnaires (SIG, CAIQ), certificates
     (ISO 27001, SOC 2), pen test summaries.
  3. Contract: security clauses, right to audit, breach notification time,
     data location, subcontractor rules, SLAs, exit plan.
  4. Ongoing monitoring: re-assessments, security ratings, news.
  5. Offboarding: data return/destruction, access removal.

1.10 BUSINESS CONTINUITY AND DISASTER RECOVERY

BCP (Business Continuity Plan): keeps critical business functions running.
DRP (Disaster Recovery Plan): restores IT systems after disruption.
BIA (Business Impact Analysis): identifies critical processes and impact of
  downtime.

Key metrics:
  - RTO (Recovery Time Objective): maximum acceptable downtime.
  - RPO (Recovery Point Objective): maximum acceptable data loss (time).
  - MTD / MAO (Maximum Tolerable Downtime).
  - MTTR (Mean Time To Repair), MTBF (Mean Time Between Failures).

Backup strategy: 3-2-1 rule (3 copies, 2 media types, 1 offsite); add
immutable/offline copies against ransomware. Test restores regularly.

Recovery site types: Hot (ready, minutes-hours), Warm (partially equipped),
Cold (space only), plus cloud-based DR.

Testing: tabletop exercise, walkthrough, simulation, parallel test, full interruption test.

1.11 DATA CLASSIFICATION AND PRIVACY

Typical classification levels: Public, Internal, Confidential, Restricted (or Top Secret/Secret/Confidential in government).
Handling rules depend on level: labelling, storage, encryption, sharing, retention, destruction.

Privacy concepts: personal data, sensitive personal data, data subject/data principal, controller/fiduciary, processor, consent, Data Protection Impact Assessment (DPIA), privacy by design, data subject access requests (DSAR), data retention and cross-border transfer mechanisms.

1.12 SECURITY AWARENESS AND CULTURE

Humans are the most frequent attack vector. Programme components:

- Onboarding training and annual refreshers
- Phishing simulations with positive reinforcement
- Role-based training (developers, admins, executives)
- Clear reporting channels with no-blame culture
- Metrics: click rate, report rate, time to report, training completion.

1.13 METRICS AND REPORTING

KPIs (performance): % systems patched within SLA, % staff trained, mean time to detect/respond, % vendors assessed, audit findings closed on time.
KRIs (risk): number of critical vulnerabilities open, privileged accounts without MFA, failed backup jobs, phishing click rate trend.

Reporting to board: keep it short, business-oriented, trend-based, show top risks, decisions needed, investment justification and comparison with peers.

1.14 GRC TOOLS

Platforms: ServiceNow GRC, Archer, OneTrust, MetricStream, LogicGate, Vanta, Drata, Secureframe, Hyperproof (compliance automation), SAP GRC.
Supporting: Excel/Sheets risk registers, JIRA tickets, vulnerability management tools, security rating services, policy management tools.

1.15 GRC ROLES AND CAREER PATH

Roles: GRC Analyst, Compliance Analyst, Risk Analyst, Internal/IT Auditor, Privacy Analyst, Third-Party Risk Analyst, Security Governance Manager, Head of GRC, CISO.

Certifications: CompTIA Security+ (foundation), ISO 27001 Lead Implementer / Lead Auditor, CISA (audit), CRISC (risk), CISM (management), CISSP (broad), CGRC (formerly CAP), CIPP / CIPM / CIPT (privacy), CDPSE, COBIT, ISO 22301 Lead Implementer, FAIR certification.

Skills: documentation, communication, analytical thinking, frameworks, stakeholder management, basic technical literacy (networks, cloud, IAM).

1.16 WORKED EXAMPLE: SIMPLE RISK REGISTER ENTRY

```
ID           : R-014
Asset        : Customer database (production)
Threat       : External attacker via stolen credentials
Vulnerability: No MFA for remote admin access
Likelihood   : 4 (Likely)
Impact       : 5 (Critical)
Inherent risk: 20 (Critical)
```

```
Existing ctrl: Strong password policy
Planned ctrl : Enforce MFA, privileged access management, session recording
Residual risk: 6 (Medium) after treatment
Owner        : Head of IT Operations
Treatment    : Mitigate
Due date     : Q2
Status       : In progress
```

1.17 COMMON MISTAKES IN GRC

- Treating compliance as a one-time project rather than continuous.
- "Paper security": policies that nobody follows.
- Risk registers that are never updated.
- Overly technical reporting that executives ignore.
- No clear risk ownership.
- Copying templates without tailoring to the business.
- Ignoring third-party and cloud risk.
- Failing to retain evidence.

1.18 INTERVIEW QUESTIONS (WITH SHORT ANSWERS)

```
Q: Difference between policy, standard, procedure and guideline?
A: Policy = intent (mandatory); standard = specific mandatory rules;
   procedure = step-by-step; guideline = recommended advice.

Q: What is the difference between a threat, vulnerability and risk?
A: Threat is what can cause harm, vulnerability is the weakness, risk is the
   likelihood and impact of a threat exploiting that weakness.

Q: How do you decide whether to accept a risk?
A: Compare to appetite/tolerance, cost of control versus expected loss,
   obtain formal sign-off from the risk owner/management and review it.

Q: What is the Statement of Applicability?
A: An ISO 27001 document listing all Annex A controls, whether each is
   applicable, implemented status and justification for inclusion/exclusion.

Q: SOC 2 Type I vs Type II?
A: Type I tests design at a single date; Type II tests operating
   effectiveness across a period.

Q: What is residual risk?
A: Risk that remains after controls and treatments are applied.

Q: How would you start a compliance programme from zero?
A: Define scope, identify obligations, inventory assets, run a gap
   assessment, prioritise remediation, write policies, implement controls,
   collect evidence, run internal audit, then pursue certification.
```

1.19 SUMMARY OF NOTE 1

```
GRC aligns security with business strategy (governance), manages uncertainty
through structured assessment and treatment (risk) and demonstrates adherence
to laws and standards (compliance). Core skills are risk assessment, policy
writing, framework knowledge (ISO 27001, NIST, SOC 2, PCI DSS, GDPR, DPDP),
audit handling, vendor risk and clear communication. Remember: compliance is
a baseline, not a guarantee of security.
```

NOTE 2: PENETRATION TESTING

2.1 INTRODUCTION

Penetration testing (pen testing, pentest) is an authorised, simulated attack on a system, network, application or organisation to find security weaknesses that a real attacker could exploit, and to demonstrate their business impact.

Unlike an automated vulnerability scan, a pen test involves human creativity: testers chain weaknesses, bypass controls, escalate privileges and prove real impact (for example, reading sensitive data or becoming domain administrator).

Goals of a pen test:
- Identify exploitable vulnerabilities before attackers do.
- Measure the effectiveness of defences and detection (blue team).
- Validate security controls and incident response.
- Meet compliance requirements (PCI DSS, ISO 27001, SOC 2, RBI, etc.).
- Prioritise remediation using real-world exploitability.
- Raise security awareness among management and developers.

LEGAL NOTE: A pen test is legal only with explicit written authorisation. In India, unauthorised access can violate Sections 43 and 66 of the IT Act, 2000. Always have a signed contract and Rules of Engagement before testing.

2.2 TYPES OF PENETRATION TESTS BY KNOWLEDGE LEVEL

BLACK BOX : Tester has no prior knowledge (simulates external attacker). Realistic but time-consuming and may miss deep issues.
WHITE BOX : Tester has full knowledge (source code, architecture, credentials). Most thorough and efficient.
GREY BOX : Partial knowledge (e.g. a normal user account, network diagram). Balanced and the most common in practice.

2.3 TYPES OF PENETRATION TESTS BY TARGET

1. NETWORK (EXTERNAL): internet-facing hosts, firewalls, VPNs, mail servers.
2. NETWORK (INTERNAL): assumes attacker already inside (malicious insider or compromised laptop); focuses on Active Directory, lateral movement, privilege escalation, segmentation.
3. WEB APPLICATION: OWASP Top 10, business logic, authentication, sessions.
4. MOBILE APPLICATION: Android/iOS (insecure storage, weak crypto, API issues, certificate pinning bypass).
5. API: REST/GraphQL/SOAP, broken object-level authorisation, mass assignment, rate limiting.
6. WIRELESS: Wi-Fi (WPA2/WPA3 weaknesses, rogue AP, evil twin).
7. CLOUD: AWS/Azure/GCP misconfigurations, IAM, storage exposure, serverless.
8. SOCIAL ENGINEERING: phishing, vishing, smishing, pretexting, USB drops, physical tailgating.
9. PHYSICAL: bypassing locks, badges, cameras, server room access.
10. RED TEAM: goal-based, stealthy, long-duration adversary simulation that tests people, process and technology including detection and response.
11. IOT / EMBEDDED / HARDWARE: firmware analysis, UART/JTAG, protocol attacks.
12. THICK CLIENT: desktop applications, memory and local storage analysis.
13. CONTAINER / KUBERNETES: image vulnerabilities, misconfigured clusters.
14. SCADA / OT / ICS: industrial control systems (done with extreme care).

Related team terms:
RED TEAM = offensive/attackers.
BLUE TEAM = defenders (SOC, incident response).
PURPLE TEAM = collaboration where red and blue share techniques to improve

detection in real time.

2.4 PENETRATION TESTING METHODOLOGIES AND STANDARDS

- PTES (Penetration Testing Execution Standard): pre-engagement, intelligence gathering, threat modelling, vulnerability analysis, exploitation, post-exploitation, reporting.
- OWASP Testing Guide (WSTG) and OWASP ASVS for web applications.
- OWASP MASVS/MASTG for mobile.
- NIST SP 800-115: Technical guide to information security testing.
- OSSTMM: Open Source Security Testing Methodology Manual.
- ISSAF: Information Systems Security Assessment Framework.
- MITRE ATT&CK: knowledge base of adversary tactics and techniques, widely used for red team planning and reporting.
- CREST, CHECK, TIBER-EU, CBEST: accredited/regulatory testing frameworks.

2.5 PHASES OF A PENETRATION TEST

PHASE 1: PRE-ENGAGEMENT / PLANNING
  - Define scope (IP ranges, domains, applications, exclusions).
  - Define objectives, timing, testing windows, test type.
  - Sign contract, NDA, Rules of Engagement (RoE), authorisation letter.
  - Emergency contacts, escalation procedure, data handling rules.
  - Decide on handling of denial-of-service, social engineering and production data risks.

PHASE 2: RECONNAISSANCE / INFORMATION GATHERING
  Passive (no direct contact with target):
    - WHOIS, DNS records, certificate transparency (crt.sh)
    - Search engines and Google dorking
    - Shodan, Censys, FOFA for exposed services
    - LinkedIn/social media (employee names, technologies)
    - GitHub/GitLab code leaks, Pastebin, breach data
    - Wayback Machine, job postings (tech stack clues)
  Active (direct interaction):
    - DNS enumeration and zone transfer attempts
    - Subdomain enumeration (Amass, Subfinder)
    - Port scanning, service/version detection (Nmap)
    - Web crawling and directory brute-forcing

PHASE 3: SCANNING AND ENUMERATION
  - Identify live hosts, open ports, services, OS fingerprints.
  - Enumerate users, shares, SNMP, LDAP, SMB, DNS, web paths.
  - Run vulnerability scanners (Nessus, OpenVAS, Nuclei) to find candidates.
  - Map attack surface and potential entry points.

PHASE 4: VULNERABILITY ANALYSIS AND THREAT MODELLING
  - Validate scanner results (remove false positives).
  - Research exploits (Exploit-DB, vendor advisories, CVE details).
  - Prioritise attack paths by likelihood and impact.

PHASE 5: EXPLOITATION
  - Attempt to gain access using verified weaknesses: weak passwords, unpatched services, injection flaws, misconfigurations, insecure deserialisation, authentication bypass.
  - Keep exploits safe and controlled; avoid crashing production systems.

PHASE 6: POST-EXPLOITATION
  - Privilege escalation (local admin/root, domain admin).
  - Credential harvesting and password cracking.
  - Lateral movement and pivoting between network segments.
  - Persistence (only if allowed by scope).
  - Data access demonstration (show proof, do not exfiltrate real sensitive data unless agreed).

```
  - Evaluate detection: did the blue team notice?

PHASE 7: REPORTING
  - Executive summary (non-technical, business risk).
  - Methodology and scope.
  - Detailed findings: title, severity (CVSS), description, affected assets,
    evidence/screenshots, steps to reproduce, impact, remediation advice,
    references (CWE/CVE/OWASP).
  - Attack narrative showing how findings chain together.
  - Positive observations (what worked well).
  - Prioritised remediation roadmap.

PHASE 8: REMEDIATION SUPPORT AND RETEST
  - Debrief meeting with technical and management audiences.
  - Retest after fixes and issue a closure report/letter of attestation.

PHASE 9: CLEANUP
  - Remove tools, accounts, shells and test data; document any changes.
```

2.6 CORE TECHNICAL AREAS AND EXAMPLE TECHNIQUES

```
(Described conceptually for learning and defence; practise only in legal labs.)

A) NETWORK PENTEST
   - Port scanning and service enumeration.
   - Exploiting outdated services (e.g. unpatched SMB, FTP, Telnet).
   - Default/weak credentials on devices (routers, printers, databases).
   - Password attacks: brute force, dictionary, password spraying,
     credential stuffing.
   - Man-in-the-middle testing (ARP spoofing, LLMNR/NBT-NS poisoning).
   - Network segmentation checks and firewall rule review.

B) ACTIVE DIRECTORY (INTERNAL)
   Common weaknesses: weak passwords, Kerberoasting (service accounts with
   crackable tickets), AS-REP roasting, unconstrained delegation, GPP
   passwords, excessive privileges, misconfigured certificate services,
   NTLM relay opportunities (when SMB signing disabled), stale admin
   accounts, shared local admin passwords (fixed by LAPS).
   Tools: BloodHound (attack-path mapping), Impacket, CrackMapExec/NetExec,
   Responder, Rubeus, Mimikatz (credential extraction in lab context).

C) WEB APPLICATION PENTEST
   - Injection (SQL, NoSQL, command, LDAP, template injection).
   - Broken authentication and session management.
   - Cross-Site Scripting (reflected, stored, DOM).
   - CSRF, SSRF, XXE, insecure deserialisation.
   - Broken access control and IDOR (insecure direct object reference).
   - File upload flaws, path traversal, local/remote file inclusion.
   - Security misconfiguration, missing headers, verbose errors.
   - Business logic flaws (price tampering, workflow bypass, race conditions).
   Tools: Burp Suite, OWASP ZAP, ffuf, sqlmap, Nikto, Nuclei, wfuzz.

D) PRIVILEGE ESCALATION
   Linux: SUID binaries, weak sudo rules, writable cron jobs, kernel exploits,
          exposed credentials, misconfigured capabilities, Docker group.
   Windows: unquoted service paths, weak service permissions, AlwaysInstallElevated,
            token impersonation, stored credentials, scheduled tasks.
   Helpers: LinPEAS, WinPEAS, GTFOBins, LOLBAS.

E) PASSWORD CRACKING
   Tools: Hashcat, John the Ripper; wordlists such as rockyou; rule-based
   attacks. Understand hash types (NTLM, bcrypt, SHA-512 crypt) and why slow
   salted hashes are safer.

F) WIRELESS
```

```
   Capture handshakes, test WPA2-PSK strength, detect rogue/evil-twin APs,
   assess WPA-Enterprise configuration. Tools: Aircrack-ng suite, Kismet.

G) CLOUD
   Check IAM over-permissions, public storage buckets, exposed metadata
   services, secrets in repositories, weak network rules, logging gaps.
   Tools: ScoutSuite, Prowler, Pacu, CloudSploit.

H) SOCIAL ENGINEERING
   Phishing campaign (GoPhish), pretext calls, tailgating. Always ethically
   scoped and HR-approved to protect employees from harm.
```

2.7 COMMON PENTEST TOOLS (OVERVIEW)

```
Operating systems : Kali Linux, Parrot OS, Commando VM, BlackArch.
Recon             : Nmap, Masscan, Amass, Subfinder, theHarvester, Maltego,
                    Recon-ng, Shodan, Wappalyzer, WhatWeb.
Vulnerability scan: Nessus, OpenVAS/Greenbone, Qualys, Nuclei, Nikto.
Web testing       : Burp Suite, OWASP ZAP, sqlmap, ffuf, Gobuster, dirsearch.
Exploitation      : Metasploit Framework, ExploitDB/searchsploit, custom
                    scripts, Sliver/Cobalt Strike/Havoc (C2 for red teams).
Password attacks  : Hashcat, John, Hydra, Medusa, CeWL, Kerbrute.
AD attacks        : BloodHound, Impacket, NetExec, Responder, Certipy.
Wireless          : Aircrack-ng, Wifite, Kismet, Bettercap.
Mobile            : MobSF, Frida, Objection, Jadx, apktool, Drozer.
Network analysis  : Wireshark, tcpdump, Netcat, Socat, Proxychains.
Reporting/notes   : Dradis, PwnDoc, Serpico, Obsidian, CherryTree, Ghostwriter.
```

2.8 SEVERITY RATING AND CVSS

```
CVSS (Common Vulnerability Scoring System) v3.1/v4.0 scores 0.0-10.0:
   None 0.0 | Low 0.1-3.9 | Medium 4.0-6.9 | High 7.0-8.9 | Critical 9.0-10.0

Base metrics: Attack Vector, Attack Complexity, Privileges Required, User
Interaction, Scope, Confidentiality/Integrity/Availability impact.
Also consider Temporal/Environmental factors, asset value, exploit
availability (EPSS, CISA KEV list) and compensating controls. A "Medium" CVSS
issue on an internet-facing crown-jewel system may deserve higher priority.
```

2.9 EXAMPLE FINDING WRITE-UP FORMAT

```
Title        : SQL Injection in Login Parameter
Severity     : Critical (CVSS 9.8)
Affected     : https://app.example.com/login (parameter: username)
Description  : The application builds SQL queries with unsanitised user input.
Evidence     : Screenshot of error message and database version disclosure.
Impact       : An attacker can bypass authentication and read or modify data.
Reproduction : 1) Open login page 2) Submit crafted input 3) Observe response.
Remediation  : Use parameterised queries/prepared statements, apply least
               privilege to the DB account, validate input, add WAF as
               defence in depth.
References   : OWASP A03:2021 Injection, CWE-89.
```

2.10 RULES OF ENGAGEMENT CHECKLIST

```
[ ] Written authorisation from asset owner (and cloud/hosting provider if
    required).
[ ] Exact scope and out-of-scope items.
[ ] Testing window and rate limits.
[ ] Allowed techniques (DoS? phishing? physical?).
[ ] Data handling, storage and destruction rules.
[ ] Emergency contact and stop-test procedure.
[ ] Reporting format and delivery channel (encrypted).
```

[ ] Liability, insurance and NDA terms.
[ ] Source IPs of the tester shared with the client.

2.11 BEST PRACTICES FOR TESTERS

- Take detailed notes and screenshots as you go.
- Never exceed scope; stop and ask if unsure.
- Avoid destructive actions in production.
- Protect client data; encrypt your evidence and laptops.
- Communicate critical findings immediately instead of waiting for the report.
- Write reports for the reader: simple language and clear fixes.
- Keep learning: CTFs, labs, new CVEs and techniques.

2.12 PRACTICE ENVIRONMENTS (LEGAL)

TryHackMe, Hack The Box, PortSwigger Web Security Academy, OWASP Juice Shop, DVWA, bWAPP, WebGoat, VulnHub, HackTheBox Academy, PentesterLab, Proving Grounds, RangeForce, CyberDefenders (blue team), and home labs with VirtualBox/VMware.

2.13 CERTIFICATIONS AND CAREER PATH

Entry: CompTIA Security+/PenTest+, eJPT, CEH (Practical), TryHackMe paths.
Intermediate: OSCP (hands-on, respected), PNPT, GPEN, CRTP, eWPT, CPTS.
Advanced: OSEP, OSWE, OSED, CRTO, GXPN, CREST CRT/CCT.
Roles: Junior Pentester, Security Consultant, Red Team Operator, Application Security Engineer, Exploit Developer, Security Researcher.

2.14 INTERVIEW QUESTIONS

Q: Difference between vulnerability scan and penetration test?
A: A scan is automated and lists potential weaknesses; a pen test is manual, validates and exploits them and shows business impact.

Q: Black, white and grey box testing?
A: Differ by amount of prior knowledge given to the tester (none, full, partial).

Q: What would you do after gaining a low-privileged shell?
A: Enumerate the system, check privilege escalation vectors, harvest credentials, explore the network for lateral movement, and document everything within scope.

Q: What is pivoting?
A: Using a compromised host as a stepping stone to reach other network segments that the tester cannot reach directly.

Q: How do you report a critical finding found mid-test?
A: Notify the agreed contact immediately through the secure channel defined in the RoE.

Q: What is the difference between a red team and pen test?
A: Pen test = broad coverage of vulnerabilities in limited time with known defenders; red team = objective-driven, stealthy emulation of real adversaries testing detection and response.

2.15 SUMMARY OF NOTE 2

Penetration testing is a structured, authorised simulation of real attacks. It follows phases from planning, recon, scanning, exploitation and post-exploitation to reporting and retesting. Strong testers combine tool knowledge with manual thinking, document clearly, stay within scope and help organisations fix problems, not just find them.

NOTE 3: VAPT (VULNERABILITY ASSESSMENT AND PENETRATION TESTING)

3.1 INTRODUCTION

VAPT combines two complementary activities:

VA - Vulnerability Assessment:
A broad, mostly automated process of discovering, classifying and prioritising vulnerabilities across systems. Answers: "What weaknesses exist?"

PT - Penetration Testing:
A focused, manual effort to exploit selected vulnerabilities and show impact. Answers: "Can an attacker actually break in, and how far can they go?"

Together, VAPT gives both breadth (coverage) and depth (proof of exploit).
In India and the wider market, "VAPT" is commonly requested by banks, fintech, e-commerce, SaaS and government bodies for compliance with RBI, SEBI, CERT-In empanelled auditor requirements, PCI DSS, ISO 27001 and customer due diligence.

3.2 VA VS PT: COMPARISON

Aspect	Vulnerability Assessment	Penetration Testing
Goal	Find and rank weaknesses	Exploit and prove impact
Approach	Mostly automated	Mostly manual + tools
Coverage	Broad	Deep, targeted
Depth	Identifies only	Exploits, chains, pivots
False positives	Possible, needs validation	Mostly validated
Frequency	Weekly/monthly/continuous	Annual or after major change
Cost/time	Lower / hours-days	Higher / days-weeks
Output	List of vulnerabilities	Attack story + proof + fixes
Skill needed	Moderate	High

3.3 WHY ORGANISATIONS NEED VAPT

- New vulnerabilities are published daily (tens of thousands of CVEs a year).
- Configuration drift and new deployments create new exposure.
- Regulators and customers demand evidence of testing.
- Helps prioritise limited patching and security budgets.
- Validates security investments and incident detection.
- Reduces breach likelihood, downtime and reputational loss.

3.4 TYPES OF VAPT ENGAGEMENTS

1. Network VAPT (internal/external)
2. Web application VAPT
3. Mobile application VAPT (Android, iOS)
4. API VAPT
5. Cloud VAPT / configuration review
6. Wireless VAPT
7. Database security assessment
8. Thick client VAPT
9. Source code review (SAST-assisted manual review)
10. Configuration/hardening review (CIS benchmarks)
11. Red team / social engineering assessments
12. IoT / firmware / OT assessments
13. Container and Kubernetes assessment

3.5 THE VAPT LIFECYCLE (STEP BY STEP)

```
STEP 1  SCOPING AND KICK-OFF
   - Identify assets: IPs, URLs, apps, APIs, cloud accounts, mobile builds.
   - Decide approach (black/grey/white box), environment (UAT vs production),
     credentials, roles to test, timelines, compliance drivers.
   - Obtain authorisation and sign NDA.

STEP 2  INFORMATION GATHERING
   - Passive and active reconnaissance to understand the attack surface.

STEP 3  VULNERABILITY ASSESSMENT
   - Run authenticated and unauthenticated scans.
   - Typical tools: Nessus, Qualys, OpenVAS, Nexpose/Rapid7, Acunetix, Burp
     Scanner, Nuclei.
   - Include manual checks for configuration and logic.

STEP 4  VALIDATION AND PRIORITISATION
   - Remove false positives, confirm findings manually.
   - Rate using CVSS plus context: exposure, exploit availability, asset
     criticality, data sensitivity.

STEP 5  PENETRATION TESTING / EXPLOITATION
   - Exploit the confirmed weaknesses in a controlled manner.
   - Attempt privilege escalation, lateral movement, data access proof.

STEP 6  REPORTING
   - Executive summary, scope, methodology, risk summary charts, detailed
     findings, remediation steps, compliance mapping (OWASP, PCI, ISO).

STEP 7  REMEDIATION
   - Client fixes issues: patching, config changes, code fixes, compensating
     controls, WAF rules.

STEP 8  RETEST / REVALIDATION
   - Tester verifies fixes; issues final clean report or certificate/letter.

STEP 9  CLOSURE AND LESSONS LEARNED
   - Root-cause analysis, secure coding training, process improvements,
     schedule next cycle.
```

3.6 WEB APPLICATION VAPT CHECKLIST (OWASP-ALIGNED)

```
OWASP Top 10 (2021) categories to test:
  A01 Broken Access Control
  A02 Cryptographic Failures
  A03 Injection
  A04 Insecure Design
  A05 Security Misconfiguration
  A06 Vulnerable and Outdated Components
  A07 Identification and Authentication Failures
  A08 Software and Data Integrity Failures
  A09 Security Logging and Monitoring Failures
  A10 Server-Side Request Forgery (SSRF)

Detailed test areas:
  - Information gathering: tech stack, robots.txt, sitemaps, hidden paths.
  - Configuration: HTTP methods, headers (CSP, HSTS, X-Frame-Options,
    X-Content-Type-Options), TLS settings, CORS, cookies flags (Secure,
    HttpOnly, SameSite), default files and error handling.
  - Authentication: password policy, lockout, MFA, reset flow, enumeration,
    default credentials, session fixation.
  - Authorisation: horizontal/vertical privilege escalation, IDOR, forced
    browsing, role tampering.
  - Session management: token randomness, expiry, logout invalidation.
```

```
  - Input validation: SQLi, XSS, command injection, XXE, SSTI, header
    injection, file upload restrictions.
  - Business logic: workflow bypass, coupon/price manipulation, race
    conditions, limits.
  - Client-side: DOM XSS, insecure storage, clickjacking, open redirects.
  - API-specific: BOLA, excessive data exposure, mass assignment, lack of
    rate limiting, improper asset management (OWASP API Top 10).
```

3.7 NETWORK VAPT CHECKLIST

```
External:
  - Open ports/services and unnecessary exposure.
  - Outdated software, missing patches, end-of-life systems.
  - Weak TLS/SSL (old protocols, weak ciphers, expired certificates).
  - Email security (SPF, DKIM, DMARC), DNS issues, subdomain takeover.
  - Exposed admin panels, default credentials, remote access (RDP, SSH).
  - VPN and firewall configuration.
Internal:
  - SMB/NetBIOS/LLMNR exposures, SMB signing status.
  - Active Directory misconfigurations and weak passwords.
  - Network segmentation and VLAN isolation.
  - Insecure protocols (Telnet, FTP, SNMP v1/v2).
  - Patch levels on servers and workstations.
  - Unsecured file shares and sensitive data exposure.
  - Database exposures and default accounts.
```

3.8 MOBILE APPLICATION VAPT CHECKLIST (OWASP MASVS)

```
  - Insecure local storage (shared preferences, SQLite, plist, keychain).
  - Hard-coded secrets and API keys in the binary.
  - Weak or missing certificate pinning; improper TLS validation.
  - Root/jailbreak detection and tamper resistance.
  - Insecure communication and API authentication.
  - Exported components, intent vulnerabilities (Android).
  - Logging of sensitive data, clipboard leaks, screenshots.
  - Reverse engineering and code obfuscation assessment.
  - Biometric and session handling checks.
```

3.9 CLOUD VAPT / CONFIGURATION REVIEW AREAS

```
  - IAM: over-privileged roles, unused keys, no MFA, root account usage.
  - Storage: publicly readable buckets/blobs, missing encryption.
  - Network: open security groups, exposed management ports.
  - Logging: CloudTrail/Activity logs, flow logs, alerts enabled?
  - Secrets management and key rotation.
  - Serverless/container security and image vulnerabilities.
  - Infrastructure as Code scanning (Terraform, CloudFormation).
  Benchmarks: CIS Benchmarks for AWS/Azure/GCP, CSA CCM.
```

3.10 VULNERABILITY MANAGEMENT PROGRAMME (BEYOND ONE-OFF VAPT)

```
Continuous cycle:
  1. Asset discovery and inventory.
  2. Regular scanning (authenticated, agent-based where possible).
  3. Prioritisation (CVSS + EPSS + KEV + business context).
  4. Remediation with SLAs, for example:
        Critical: 7 days (or immediately if actively exploited)
        High    : 30 days
        Medium  : 60-90 days
        Low     : next maintenance window
  5. Verification by rescan.
  6. Reporting and metrics (mean time to remediate, aging, coverage).
```

```
  7. Exception handling with documented risk acceptance.

Metrics: % assets scanned, number of critical/high open, SLA compliance,
recurring vulnerability rate, mean time to remediate.
```

3.11 SAMPLE VAPT REPORT STRUCTURE

```
1. Cover page and document control (version, confidentiality, dates)
2. Executive summary (overall posture, key risks, top recommendations)
3. Scope and objectives
4. Methodology and standards used
5. Risk rating criteria
6. Summary of findings (counts by severity, charts)
7. Detailed findings (each with description, impact, evidence, fix)
8. Positive observations
9. Remediation roadmap with priorities
10. Retest results
11. Appendices: tools used, raw scan output, test accounts, glossary
12. Tester declaration / sign-off
```

3.12 COMMON FINDINGS SEEN IN VAPT (WITH TYPICAL FIXES)

```
Finding                                | Typical remediation
---------------------------------------|---------------------------------------
Outdated/unpatched software            | Patch management, upgrade EOL systems
Weak/default passwords                 | Strong policy, MFA, remove defaults
SQL injection                          | Parameterised queries, least privilege
Cross-site scripting                   | Output encoding, CSP, input validation
Missing security headers               | Configure web server/app headers
Insecure TLS configuration             | Disable old protocols, strong ciphers
Broken access control / IDOR           | Server-side authorisation checks
Information disclosure (verbose errors)| Custom error pages, disable debug
Exposed admin interfaces               | Restrict by IP/VPN, MFA
Open management ports (RDP/SSH)        | Restrict, use VPN/bastion, rate limit
Sensitive data in cleartext            | Encrypt in transit and at rest
Missing rate limiting                  | Throttling, CAPTCHA, lockout
Hard-coded secrets                     | Use secrets manager, rotate keys
Public cloud storage                   | Block public access, least privilege
Lack of logging/monitoring             | Centralised logging, SIEM alerts
```

3.13 COMPLIANCE LINKAGE

```
PCI DSS Req. 11: regular internal/external scans (ASV for external) and
  penetration testing at least annually and after significant changes.
ISO 27001 Annex A: technical vulnerability management and security testing.
SOC 2: vulnerability management evidence under Security criteria.
RBI/SEBI: periodic VAPT and audit of critical applications and
  infrastructure.
CERT-In: empanelled auditors perform government-recognised audits.
HIPAA: risk analysis and technical evaluations.
```

3.14 TOOLS SUMMARY FOR VAPT

```
Scanners  : Nessus, Qualys, OpenVAS, Rapid7 InsightVM, Acunetix, Netsparker
            (Invicti), Nuclei, Nikto, Trivy (containers), Dependency-Check.
Web       : Burp Suite Pro, OWASP ZAP, sqlmap, ffuf, Postman (API).
Network   : Nmap, Metasploit, Wireshark, Hydra, Responder, Impacket.
Mobile    : MobSF, Frida, Objection, ADB, Jadx.
Cloud     : Prowler, ScoutSuite, Pacu, CloudSploit.
Code      : SonarQube, Semgrep, Checkmarx, Fortify, Bandit.
Reporting : Dradis, Faraday, DefectDojo (also tracks remediation).
```

3.15 CHALLENGES IN VAPT

- False positives and false negatives from scanners.
- Scope creep and unclear boundaries.
- Risk of disrupting production services.
- WAF/IPS blocking or rate-limiting testers.
- Limited testing time compared with real attackers.
- Poor remediation follow-through.
- Dynamic cloud assets changing faster than tests.

3.16 BEST PRACTICES

- Test in staging that mirrors production; use production carefully.
- Combine automated scanning with manual testing.
- Retest after every fix and major release.
- Integrate security in CI/CD (SAST, DAST, SCA) - "shift left".
- Track findings in a ticketing/defect system with owners and due dates.
- Use risk-based prioritisation instead of CVSS alone.
- Rotate testing vendors/teams for fresh perspectives.
- Share lessons learned with developers via training.

3.17 INTERVIEW QUESTIONS

Q: What does VAPT stand for and why is it needed?
A: Vulnerability Assessment and Penetration Testing; to find, validate and
   fix weaknesses before attackers exploit them and to meet compliance.

Q: How do you handle false positives?
A: Manually verify with a second tool or proof-of-concept, check versions and
   configurations, and document as false positive if not exploitable.

Q: What is authenticated scanning and why use it?
A: Scanning with valid credentials, giving deeper visibility into patches,
   configs and local vulnerabilities with fewer false positives.

Q: How do you prioritise vulnerabilities?
A: CVSS score plus exploit availability (EPSS/KEV), exposure, asset
   criticality, data sensitivity and compensating controls.

Q: What is the difference between SAST, DAST and IAST?
A: SAST analyses source code statically; DAST tests a running app from
   outside; IAST instruments the running app to observe vulnerabilities
   from inside.

Q: Explain a vulnerability you would rate critical.
A: Unauthenticated remote code execution on an internet-facing server that
   holds sensitive data.

3.18 SUMMARY OF NOTE 3

VAPT merges wide automated discovery (VA) with expert manual exploitation
(PT). A good VAPT follows a lifecycle from scoping to retest, produces clear
actionable reports and feeds a continuous vulnerability management process.
Prioritise by real risk, fix quickly, verify, and use findings to improve
development and operations.

NOTE 4: ETHICAL HACKING

4.1 INTRODUCTION

Ethical hacking is the authorised practice of probing systems, networks and applications using the same knowledge and tools as malicious attackers, but with permission and with the goal of improving security. An ethical hacker is sometimes called a "white hat". Ethical hacking is the broad discipline; penetration testing, red teaming, bug bounty hunting and security research are specific ways to practise it.

The core principle: "Think like an attacker, act like a professional."

Three things make hacking ethical:

1. PERMISSION - written authorisation from the system owner.
2. SCOPE - staying strictly within agreed targets and methods.
3. INTENT - reporting and helping fix problems, never causing harm, stealing data or profiting illegally.

4.2 TYPES OF HACKERS

White hat : Ethical, authorised security professionals.
Black hat : Malicious attackers who break laws for profit, disruption or revenge.
Grey hat : Break in without permission but often without malicious intent (for example, reporting a flaw afterwards). Still illegal in most places.
Script kiddie: Low-skill attackers using ready-made tools.
Hacktivist : Attacks motivated by political or social causes.
State-sponsored / APT : Well-funded, persistent, highly skilled groups working for governments.
Insider : Employees or contractors misusing legitimate access.
Red hat : Vigilantes who attack black hats (unofficial term).
Blue hat : External testers invited to test software before release, or revenge-driven attackers depending on the definition.

4.3 THE HACKER MINDSET

- Curiosity: ask "what happens if I change this?"
- Persistence: failed attempts are information.
- Lateral thinking: combine small weaknesses into a big one.
- Understanding fundamentals: protocols, operating systems, programming.
- Documentation: keep notes for reproducibility and reporting.
- Responsibility: protect the data you touch.

4.4 THE FIVE (SIX) PHASES OF ETHICAL HACKING

PHASE 1: RECONNAISSANCE (FOOTPRINTING)
Gathering information about the target.
Passive: WHOIS, DNS, OSINT, social media, job posts, leaked data.
Active: ping sweeps, DNS queries, banner grabbing.

PHASE 2: SCANNING
Discovering live hosts, open ports, services, OS, vulnerabilities.
Port scanning, network mapping, vulnerability scanning.

PHASE 3: GAINING ACCESS
Exploiting a weakness to enter: password attacks, software flaws, misconfigurations, social engineering, web flaws.

PHASE 4: MAINTAINING ACCESS

```
   Persistence mechanisms an attacker would use (backdoors, scheduled tasks,
   new accounts). Ethical hackers simulate or document these only when allowed.

PHASE 5: COVERING TRACKS
   Attackers delete or alter logs and hide activity. Ethical hackers do not
   destroy evidence but assess whether logging and detection would catch
   such behaviour.

PHASE 6: REPORTING (the ethical addition)
   Document findings, impact and fixes. This phase separates professionals
   from criminals.
```

4.5 FOOTPRINTING AND OSINT

```
OSINT = Open Source Intelligence from public sources.
Sources: company website, press releases, employee profiles, DNS/WHOIS,
certificate transparency logs, code repositories, cloud storage indexes,
breach corpora, archive services, Shodan/Censys device search.
Tools: theHarvester, Recon-ng, Maltego, SpiderFoot, Amass, Sublist3r,
Google dorks (operators such as site:, filetype:, inurl:, intitle:).
Defence: limit public data, remove metadata from documents, monitor leaks,
train staff on oversharing, enforce DMARC to reduce spoofing.
```

4.6 FOUNDATIONS EVERY ETHICAL HACKER MUST KNOW

```
NETWORKING
  - OSI (7 layers) and TCP/IP (4 layers) models.
  - IP addressing, subnetting, CIDR, NAT, routing, VLANs.
  - TCP three-way handshake (SYN, SYN-ACK, ACK) and flags (SYN, ACK, FIN,
    RST, PSH, URG); UDP basics.
  - Key protocols: HTTP/HTTPS, DNS, DHCP, ARP, ICMP, SMB, FTP, SSH, SMTP,
    LDAP, Kerberos, SNMP, RDP, TLS.
  - Common ports: 21 FTP, 22 SSH, 23 Telnet, 25 SMTP, 53 DNS, 80 HTTP,
    110 POP3, 135/139/445 Windows/SMB, 143 IMAP, 389 LDAP, 443 HTTPS,
    1433 MSSQL, 3306 MySQL, 3389 RDP, 5432 PostgreSQL, 8080 alt HTTP.

OPERATING SYSTEMS
  - Linux: file permissions, users/groups, services, cron, package managers,
    shell scripting (bash).
  - Windows: registry, services, Active Directory, PowerShell, event logs,
    NTFS permissions.

PROGRAMMING AND SCRIPTING
  - Python (automation, exploit PoCs), Bash, PowerShell, JavaScript (web),
    SQL, C/C++ (memory issues), Assembly basics (reverse engineering).

WEB TECHNOLOGIES
  - HTTP methods, status codes, headers, cookies, sessions, JWT, CORS, SOP.
  - HTML, JavaScript, REST APIs, databases and frameworks.

SECURITY CONCEPTS
  - CIA triad, authentication vs authorisation, encryption and hashing,
    least privilege, defence in depth.
```

4.7 SCANNING AND ENUMERATION IN DETAIL

```
Host discovery: ICMP echo, ARP scan (local), TCP/UDP probes.
Port scan types (Nmap examples conceptually):
  - TCP Connect scan : completes full handshake (noisy, no special rights).
  - SYN (half-open)  : sends SYN, waits for SYN-ACK, then resets (faster,
                       stealthier).
  - UDP scan         : slower, finds DNS, SNMP, DHCP, etc.
  - ACK scan         : maps firewall rules.
```

```
  - FIN/Xmas/Null    : evasion-oriented scans on some stacks.
  - Version detection (-sV), OS detection (-O), default scripts (-sC) and
    the Nmap Scripting Engine (NSE).
Banner grabbing: reading service banners to identify software and versions.

Port states: open, closed, filtered (firewall drops), open|filtered.

Enumeration targets:
  - SMB shares and null sessions, NetBIOS names.
  - SNMP community strings and MIB data.
  - LDAP/Active Directory users, groups, policies.
  - DNS records (A, AAAA, MX, NS, TXT, SRV) and zone transfers.
  - SMTP user verification (VRFY/EXPN).
  - Web: directories, parameters, technologies, APIs.
Defence: disable unnecessary services, restrict SNMP/SMB, use firewalls and
IDS/IPS, disable zone transfers except to authorised servers, hide banners
where practical, monitor scanning behaviour.
```

4.8 SYSTEM HACKING CONCEPTS

```
PASSWORD ATTACKS
  - Online: brute force, dictionary, password spraying (one password against
    many users), credential stuffing (leaked pairs reused).
  - Offline: cracking hashes with wordlists, rules and GPUs; rainbow tables
    (defeated by salting).
  - Defences: long unique passwords/passphrases, MFA, lockout/throttling,
    password managers, breached-password screening, salted slow hashes
    (bcrypt, scrypt, Argon2), monitoring.

PRIVILEGE ESCALATION
  - Vertical: normal user becomes admin/root.
  - Horizontal: access another user's data at the same level.
  - Causes: unpatched kernels, weak permissions, misconfigured services,
    stored credentials, insecure sudo.
  - Defence: patching, least privilege, hardening baselines, auditing.

MALWARE-RELATED CONCEPTS
  Ethical hackers must understand viruses, worms, trojans, ransomware,
  rootkits, keyloggers, RATs and fileless malware to test endpoint
  protection and detection (see Note 11).

STEGANOGRAPHY AND COVERT CHANNELS
  Hiding data inside images/audio/protocols. Detection via file analysis
  and traffic baselining.

LOG HANDLING
  Attackers tamper with logs; defenders forward logs to a central SIEM with
  write-once storage and integrity checks.
```

4.9 WEB AND APPLICATION HACKING (OVERVIEW)

```
Key attack classes to study (details in Notes 6, 7 and 9):
  - SQL injection, command injection, XSS, CSRF, SSRF, XXE
  - Broken authentication, session hijacking, IDOR
  - File upload and inclusion flaws, deserialisation
  - Business logic abuse, API abuse
Recommended learning path: PortSwigger Web Security Academy -> OWASP Juice
Shop -> DVWA/WebGoat -> bug bounty practice on authorised programmes.
```

4.10 WIRELESS, MOBILE, IOT AND CLOUD HACKING (OVERVIEW)

```
WIRELESS: WEP is broken; WPA2-Personal depends on passphrase strength;
  WPA3 improves protection (SAE). Risks: evil twin, rogue AP, deauth,
  weak enterprise settings. Defence: WPA3/WPA2-Enterprise, certificate
```

```
  validation, WIPS, strong passphrases, guest isolation.
MOBILE: insecure storage, weak TLS, hard-coded secrets, exported components,
  jailbreak/root weaknesses. Defence: OWASP MASVS controls.
IOT: default credentials, outdated firmware, insecure update channels,
  open debug ports, cleartext protocols. Defence: change defaults, patch,
  segment IoT, signed firmware.
CLOUD: IAM misconfiguration, exposed storage, leaked keys, metadata service
  abuse. Defence: least privilege, CSPM tools, logging, secret scanning.
```

4.11 SOCIAL ENGINEERING (HUMAN HACKING)

```
Techniques: phishing, spear phishing, whaling (executives), vishing (voice),
smishing (SMS), pretexting (invented scenario), baiting (infected USB or
free offers), tailgating/piggybacking, quid pro quo, impersonation,
shoulder surfing, dumpster diving, business email compromise (BEC).
Psychological levers: authority, urgency, scarcity, liking, reciprocity,
social proof, fear.
Defence: awareness training, verification procedures (call back on known
numbers), email filtering, DMARC/DKIM/SPF, MFA, physical access controls,
clear reporting channel.
```

4.12 ETHICS, LAW AND PROFESSIONAL CONDUCT

```
Principles: authorisation, confidentiality, integrity, honesty, minimal
harm, responsible disclosure, competence, respect for privacy.

Laws (examples; always check your jurisdiction):
  - India: IT Act 2000 (Sections 43, 66, 66B-66F, 67), Bharatiya Nyaya
    Sanhita provisions, DPDP Act 2023.
  - USA: Computer Fraud and Abuse Act (CFAA).
  - UK: Computer Misuse Act 1990.
  - EU: GDPR, NIS2, national cybercrime laws.

Responsible disclosure: report the flaw privately to the vendor or owner,
allow reasonable time to fix (commonly 60-90 days), avoid public release of
exploit details before a fix, and follow bug bounty programme rules.
Coordinated disclosure bodies: CERT-In, CERT/CC, vendor PSIRTs.

Bug bounty platforms: HackerOne, Bugcrowd, Intigriti, YesWeHack, Synack and
company-run programmes. Always read scope and rules; out-of-scope testing may
be illegal.
```

4.13 BUILDING A HOME LAB

```
Hardware: laptop/PC with 16 GB RAM (8 GB minimum), SSD, virtualisation
support.
Software: VirtualBox, VMware Workstation Player, or Proxmox.
Attacker VM: Kali Linux or Parrot OS.
Targets: Metasploitable 2/3, DVWA, OWASP Juice Shop, WebGoat, VulnHub
machines, Windows evaluation VMs, a small Active Directory lab.
Network: use host-only or NAT networks, isolated from your home devices.
Extras: Wireshark capture practice, pfSense firewall, Security Onion or
Wazuh for the defensive side, Splunk free tier or ELK for logs.
Rule: never connect vulnerable VMs to the open internet.
```

4.14 ETHICAL HACKER TOOLKIT SUMMARY

```
Recon      : Nmap, Maltego, theHarvester, Shodan, Amass, SpiderFoot.
Scanning   : Nmap, Nessus, OpenVAS, Nikto, Nuclei.
Web        : Burp Suite, OWASP ZAP, sqlmap, ffuf.
Exploitation: Metasploit, searchsploit, custom scripts.
Passwords  : Hashcat, John the Ripper, Hydra.
Sniffing   : Wireshark, tcpdump, Bettercap.
```

```
Wireless   : Aircrack-ng, Kismet.
Forensics  : Autopsy, Volatility, FTK Imager.
Social eng.: GoPhish, SET (Social-Engineer Toolkit) in authorised campaigns.
Reverse eng.: Ghidra, IDA Free, x64dbg, Radare2.
```

4.15 CERTIFICATIONS AND CAREER PATH

```
Foundation  : CompTIA Network+/Security+, CEH (EC-Council), eJPT.
Practical   : PNPT, OSCP, CPTS, CRTP, eCPPT.
Specialist  : OSWE (web), OSEP (evasion), OSED (exploit dev), GXPN, CREST.
Roles       : Ethical Hacker, Penetration Tester, Red Team Operator, Bug
              Bounty Hunter, Security Researcher, Application Security
              Engineer, Threat Hunter (with offensive background).
Typical learning path:
  Networking and Linux -> Python/Bash -> web basics -> TryHackMe/HTB ->
  CTFs -> certification -> specialisation -> contribute (blogs, tools,
  bug bounty).
```

4.16 INTERVIEW QUESTIONS

```
Q: What is the difference between ethical hacking and cracking?
A: Ethical hacking is authorised and aims to improve security; cracking
   (malicious hacking) is unauthorised and intended to harm or profit.

Q: What are the phases of hacking?
A: Reconnaissance, scanning, gaining access, maintaining access, covering
   tracks, and (ethically) reporting.

Q: What is footprinting?
A: Collecting information about a target to understand its attack surface.

Q: Active vs passive reconnaissance?
A: Passive uses public sources without touching the target; active
   interacts directly and may be detected.

Q: Explain a TCP SYN scan.
A: Sends SYN; if SYN-ACK is returned the port is open and the scanner
   resets instead of completing the handshake.

Q: How do you defend against password spraying?
A: MFA, smart lockout, monitoring failed-login patterns across accounts,
   banning common passwords, and conditional access.

Q: What would you do if you discovered a vulnerability in a website you do
   not own?
A: Do not exploit it further; report it responsibly through the owner's
   security contact or bug bounty programme.
```

4.17 SUMMARY OF NOTE 4

```
Ethical hacking applies attacker techniques under permission to strengthen
security. It rests on solid fundamentals (networking, operating systems,
scripting, web), a repeatable methodology (recon to reporting), strict legal
and ethical conduct, and continuous practice in safe labs. Always remember:
authorisation, scope and responsible disclosure define the ethical hacker.
```

NOTE 5: NETWORK SECURITY

5.1 INTRODUCTION

Network security is the set of policies, practices and technologies used to protect the confidentiality, integrity and availability of data in transit and of the network infrastructure itself. It protects against unauthorised access, misuse, modification, denial of service and eavesdropping.

Modern networks include on-premises LANs, WANs, data centres, wireless, remote access, cloud networks (VPC/VNet), SD-WAN, IoT and OT segments, so network security must be layered, identity-aware and continuously monitored.

5.2 NETWORKING FUNDAMENTALS RECAP

OSI MODEL (and security relevance)

```
  7 Application  : HTTP, DNS, SMTP     - WAF, app-layer attacks
  6 Presentation : TLS, encoding       - encryption, format attacks
  5 Session      : sessions, RPC       - session hijacking
  4 Transport    : TCP, UDP            - port scans, SYN floods, firewalls
  3 Network      : IP, ICMP, routing   - IP spoofing, routing attacks, ACLs
  2 Data link    : Ethernet, ARP, VLAN - ARP spoofing, MAC flooding, 802.1X
  1 Physical     : cables, radio       - tapping, jamming, physical access
```

TCP/IP MODEL: Application, Transport, Internet, Network access.

KEY DEVICES: hub, switch (L2/L3), router, firewall, IDS/IPS, proxy, load balancer, VPN gateway, WAF, NAC, wireless controller, access points.

ADDRESSING: IPv4 (32-bit), IPv6 (128-bit), private ranges (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16), NAT/PAT, DHCP, DNS.

5.3 CORE SECURITY GOALS AND PRINCIPLES

- CIA Triad (confidentiality, integrity, availability).
- AAA: Authentication, Authorisation, Accounting.
- Defence in depth: multiple layers (perimeter, network, host, application, data, people).
- Least privilege and need-to-know.
- Zero Trust: "never trust, always verify" - authenticate and authorise every request regardless of network location, assume breach, use micro-segmentation and continuous validation (NIST SP 800-207).
- Segmentation: limit blast radius using VLANs, subnets, firewalls and ACLs.
- Secure by default and fail-safe defaults.
- Separation of duties.
- Visibility: log, monitor and alert.

5.4 FIREWALLS

Purpose: control traffic between networks according to rules.

Types:

1. Packet-filtering (stateless): checks source/destination IP, port, protocol per packet. Fast, limited context.
2. Stateful inspection: tracks connection state (e.g. only allows replies to outbound requests). Most common baseline.
3. Proxy / application gateway: terminates and inspects sessions at the application level.
4. Next-Generation Firewall (NGFW): adds application awareness, IPS, user identity, TLS inspection, threat intelligence, URL filtering.
5. Web Application Firewall (WAF): protects web apps from injection, XSS,

```
     bots and some API abuse.
  6. Host-based firewall: on endpoints/servers (Windows Defender Firewall,
     iptables/nftables, ufw).
  7. Cloud firewalls / security groups / NACLs.

Rule design best practices:
  - Default deny, allow only what is required.
  - Order rules from specific to general; document purpose and owner.
  - Review and clean up unused/overly broad rules (any-any).
  - Restrict management interfaces and use MFA.
  - Log denied and critical allowed traffic.
  - Separate zones: Internet, DMZ, internal, management, guest, OT.

DMZ (Demilitarised Zone): a network segment hosting public-facing services
(web, mail, DNS) isolated from the internal LAN so compromise of a DMZ host
does not directly expose internal systems.

Example ACL concept:
  permit tcp any host WEB-SERVER eq 443
  permit tcp ADMIN-NET host WEB-SERVER eq 22
  deny   ip  any any log
```

5.5 IDS AND IPS

```
IDS (Intrusion Detection System): monitors and alerts.
IPS (Intrusion Prevention System): inline; detects and blocks.

By placement:
  NIDS/NIPS : network-based, watches traffic at key points.
  HIDS/HIPS : host-based, watches logs, files, processes.

By detection method:
  Signature-based : matches known attack patterns (accurate for known, blind
                    to new).
  Anomaly-based   : compares against baseline behaviour (can find unknown but
                    produces false positives).
  Heuristic/behavioural and reputation-based methods.

Tools: Snort, Suricata, Zeek (network analysis), OSSEC/Wazuh (HIDS), Security
Onion, commercial NGFW/IPS modules.

Concepts: true/false positive, true/false negative, tuning, alert fatigue,
evasion (fragmentation, encryption, obfuscation).
```

5.6 VPN AND SECURE REMOTE ACCESS

```
VPN creates an encrypted tunnel over an untrusted network.
Types:
  - Site-to-site VPN (connect offices/clouds) usually IPsec.
  - Remote-access VPN (users to corporate network): IPsec/IKEv2, SSL/TLS
    VPN, OpenVPN, WireGuard.
  - ZTNA (Zero Trust Network Access): per-application access with identity
    and device posture checks, replacing broad VPN access.

IPsec components: AH (integrity/authentication), ESP (confidentiality +
integrity), IKE (key exchange), Transport mode vs Tunnel mode, Security
Associations.

Split tunnelling: only corporate traffic uses VPN (performance, but less
control); full tunnelling sends all traffic through VPN.

Best practices: MFA, patch VPN appliances quickly (they are prime targets),
restrict by device posture, log sessions, avoid exposing management
interfaces, use strong ciphers.
```

5.7 SECURE PROTOCOLS: WHAT TO USE INSTEAD OF WHAT

```
Insecure     -> Secure alternative
Telnet       -> SSH
FTP          -> SFTP / FTPS
HTTP         -> HTTPS (TLS 1.2/1.3)
SMTP/POP3/IMAP plain -> with STARTTLS/TLS
SNMP v1/v2c  -> SNMP v3
LDAP plain   -> LDAPS / LDAP with StartTLS
DNS plain    -> DNSSEC, DoT/DoH where appropriate
WEP/WPA      -> WPA3 / WPA2-Enterprise
NTLM         -> Kerberos / modern auth where possible
SMBv1        -> SMBv3 with signing and encryption
RDP exposed  -> RDP behind VPN/gateway with NLA and MFA
```

TLS notes: disable SSLv3, TLS 1.0, 1.1; prefer TLS 1.2/1.3 with forward secrecy ciphers; use valid certificates, HSTS, OCSP stapling; monitor expiry.

5.8 NETWORK ACCESS CONTROL AND SWITCH/LAN SECURITY

NAC: checks device identity and posture before granting network access.
IEEE 802.1X: port-based authentication using supplicant, authenticator and RADIUS authentication server (EAP methods).
Switch security features:

- Port security (limit MAC addresses per port).
- DHCP snooping (blocks rogue DHCP servers).
- Dynamic ARP Inspection (prevents ARP spoofing).
- IP Source Guard.
- BPDU Guard and Root Guard (protect spanning tree).
- Disable unused ports; put them in an unused VLAN.
- Prevent VLAN hopping: disable DTP, avoid native VLAN 1, prune trunks.
- Private VLANs and microsegmentation.

Management plane: SSH only, AAA via TACACS+/RADIUS, out-of-band management network, SNMPv3, NTP with authentication, config backups and change control.

5.9 WIRELESS NETWORK SECURITY

Standards: 802.11 a/b/g/n/ac/ax (Wi-Fi 4/5/6/6E).
Security protocols: WEP (broken), WPA (deprecated), WPA2 (AES-CCMP), WPA3 (SAE, protected management frames, stronger encryption).
Modes: Personal (pre-shared key) vs Enterprise (802.1X/RADIUS).
Risks: rogue AP, evil twin, deauthentication, KRACK-style protocol flaws, weak passphrases, WPS PIN weaknesses, guest-to-internal pivot.
Controls: WPA3/WPA2-Enterprise, strong unique passphrases, disable WPS, separate SSIDs/VLANs for guest and IoT, WIPS/WIDS, certificate validation on clients, regular firmware updates, power-level tuning, MAC filtering only as a minor addition (not real security).

5.10 DNS, EMAIL AND WEB SECURITY

DNS: protect with DNSSEC, restrict zone transfers, disable open recursion, use protective DNS filtering, monitor for tunnelling and DGA domains, guard against cache poisoning and subdomain takeover.
EMAIL: SPF (authorised sending IPs), DKIM (message signing), DMARC (policy and reporting), secure email gateways, attachment sandboxing, link rewriting, user reporting button, MTA-STS and TLS-RPT.
WEB: secure web gateway/proxy, URL categorisation, TLS inspection where legal and ethical, WAF, CDN/DDoS protection, security headers.

5.11 DDOS PROTECTION AND AVAILABILITY

```
Threat types: volumetric floods, protocol attacks (SYN floods), and
application-layer attacks (HTTP floods).
Mitigation: CDN and scrubbing services (e.g. Cloudflare, Akamai, AWS
Shield), rate limiting, SYN cookies, anycast, over-provisioned bandwidth,
blackhole/sinkhole routing with ISP, autoscaling, WAF rules, redundant
architecture, and a tested DDoS runbook.
```

5.12 NETWORK MONITORING AND SIEM

```
Data sources: firewall, IDS/IPS, NetFlow/IPFIX, DNS, proxy, DHCP, VPN,
authentication, endpoint (EDR), cloud logs, packet captures.
SIEM (Security Information and Event Management): collects, normalises,
correlates and alerts (Splunk, Microsoft Sentinel, IBM QRadar, Elastic,
Wazuh, Chronicle).
SOAR: automates response playbooks.
NDR (Network Detection and Response): analytics on network behaviour.
Packet analysis: Wireshark, tcpdump, Zeek logs.
Baselines and use-cases: unusual outbound traffic, beaconing, lateral
movement, port scans, large data transfers, impossible travel logins.
```

5.13 NETWORK DESIGN AND ARCHITECTURE

```
Recommended zones:
  Internet -> Edge firewall -> DMZ (public services)
                            -> Internal user LAN
                            -> Server/data-centre zone
                            -> Management network (jump hosts)
                            -> Guest Wi-Fi (internet only)
                            -> IoT/OT zone (restricted)
Good design: redundancy (HA firewalls, dual ISP), secure routing (route
authentication, prefix filters), egress filtering (block unexpected outbound
traffic, restrict DNS), network time sync, backup configs, documented
network diagrams and data flows.
Cloud networking: VPC/VNet design, security groups, NACLs, private
endpoints, transit gateways, flow logs, no public management ports.
```

5.14 HARDENING CHECKLIST

```
[ ] Change default passwords; use unique admin accounts and MFA.
[ ] Update firmware and OS regularly; track end-of-life.
[ ] Disable unused services, ports and protocols.
[ ] Enforce secure management (SSH, HTTPS, out-of-band).
[ ] Apply CIS benchmark baselines to routers, switches, firewalls.
[ ] Segment networks and restrict east-west traffic.
[ ] Enable logging, NTP and central log forwarding.
[ ] Implement egress filtering.
[ ] Back up configurations and test restoration.
[ ] Scan and test regularly (VAPT).
[ ] Maintain asset inventory and network diagrams.
```

5.15 TOOLS FOR NETWORK SECURITY PROFESSIONALS

```
Scanning/diagnostics : Nmap, Netcat, traceroute, ping, hping3, iperf.
Packet analysis      : Wireshark, tcpdump, tshark, NetworkMiner.
IDS/IPS/NSM          : Snort, Suricata, Zeek, Security Onion.
Firewalls            : pfSense, OPNsense, iptables/nftables, Palo Alto,
                       Fortinet, Cisco, Check Point.
Vulnerability scans  : Nessus, OpenVAS, Qualys.
SIEM/log             : Splunk, ELK/Elastic, Wazuh, Graylog, Sentinel.
Simulation labs      : Cisco Packet Tracer, GNS3, EVE-NG.
```

5.16 CAREER AND CERTIFICATIONS

Roles: Network Security Engineer, Firewall Engineer, SOC Analyst, Security Architect, Network Administrator (security focus).
Certs: CompTIA Network+ and Security+, Cisco CCNA/CCNP Security, Palo Alto PCNSA/PCNSE, Fortinet NSE, Check Point CCSA, CEH, CISSP, GIAC GSEC/GCIA, JNCIA-SEC.

5.17 INTERVIEW QUESTIONS

Q: Stateful vs stateless firewall?
A: Stateful tracks connection state and allows return traffic automatically; stateless evaluates each packet independently using static rules.

Q: IDS vs IPS?
A: IDS detects and alerts (passive/out-of-band); IPS sits inline and can block malicious traffic.

Q: What is a DMZ?
A: A buffer network hosting public services, isolated from the internal LAN.

Q: How does DHCP snooping help?
A: It blocks rogue DHCP servers and builds a binding table used by Dynamic ARP Inspection and IP Source Guard.

Q: What is Zero Trust?
A: A security model that verifies every user, device and request, grants least privilege and assumes the network is already compromised.

Q: TCP vs UDP?
A: TCP is connection-oriented and reliable; UDP is connectionless, faster and without delivery guarantees.

Q: How would you secure a branch office network?
A: Segment VLANs, NGFW with IPS, site-to-site VPN/SD-WAN, 802.1X, secure Wi-Fi, central logging, hardened switches, patching and backups.

5.18 SUMMARY OF NOTE 5

Network security protects data in motion and the infrastructure carrying it through layered controls: segmentation, firewalls, IDS/IPS, secure protocols, VPN/ZTNA, NAC, wireless protection, DNS/email/web security, DDoS defences and continuous monitoring. Design for default-deny, least privilege and visibility, and test regularly.

NOTE 6: VULNERABILITIES

6.1 INTRODUCTION

A vulnerability is a weakness in a system, process, design, implementation or human behaviour that can be exploited by a threat to compromise confidentiality, integrity or availability.

Relationship:
  THREAT (who/what can harm) exploits a VULNERABILITY (weakness) in an ASSET producing RISK (likelihood x impact). Controls reduce vulnerability, likelihood or impact.

Vulnerabilities are inevitable: software is complex, humans make mistakes and configurations drift. The goal is to find, prioritise and remediate them faster than attackers can exploit them.

6.2 SOURCES / ROOT CAUSES OF VULNERABILITIES

1. Coding errors: buffer overflows, injection, race conditions.
2. Design flaws: missing authorisation, insecure workflows, weak crypto design.
3. Misconfiguration: default credentials, open ports, excessive permissions, debug mode enabled, public cloud storage.
4. Outdated software: unpatched operating systems, libraries, firmware.
5. Weak authentication: guessable passwords, no MFA, reused credentials.
6. Complexity: large attack surface, legacy systems, many integrations.
7. Supply chain: vulnerable or malicious third-party components.
8. Human factors: phishing susceptibility, poor training, shadow IT.
9. Physical weaknesses: unlocked rooms, exposed ports and devices.
10. Process gaps: no patch management, no change control, no monitoring.

6.3 CATEGORIES OF VULNERABILITIES

```
HARDWARE      : Spectre/Meltdown-style CPU flaws, firmware bugs, Rowhammer,
                insecure boot, side channels, supply-chain tampering.
OPERATING SYSTEM / KERNEL: privilege escalation, memory corruption, driver
                flaws, insecure services.
APPLICATION   : web, mobile, desktop flaws (see Note 7).
NETWORK       : open services, weak protocols, misconfigured devices.
DATABASE      : default accounts, injection, excessive privileges, unencrypted
                data, exposed ports.
CLOUD         : IAM misconfiguration, exposed storage, insecure APIs, shared
                responsibility misunderstandings.
HUMAN / PROCESS: social engineering, insider misuse, weak policies.
PHYSICAL      : tailgating, unsecured server rooms, stolen devices.
CRYPTOGRAPHIC : weak algorithms, bad key management, poor randomness.
SUPPLY CHAIN  : compromised updates, malicious packages, vulnerable
                dependencies, vendor access abuse.
ZERO-DAY      : unknown to the vendor, no patch available.
N-DAY         : known and patched, but not yet applied by the victim.
```

6.4 COMMON VULNERABILITY CLASSES (CONCEPTS AND DEFENCES)

```
BUFFER OVERFLOW / MEMORY CORRUPTION
  Writing more data than a buffer can hold overwrites adjacent memory, which
  can crash a program or allow code execution. Variants: stack overflow, heap
  overflow, use-after-free, integer overflow, format string.
  Defences: memory-safe languages (Rust, Go, managed languages), bounds
  checking, ASLR, DEP/NX, stack canaries, CFI, compiler hardening, fuzzing.
```

INJECTION (SQL, OS COMMAND, LDAP, NOSQL, TEMPLATE)
  Untrusted input is interpreted as code/commands. Defences: parameterised
  queries, ORM safe usage, input validation, escaping, least privilege.

CROSS-SITE SCRIPTING (XSS)
  Attacker-controlled script runs in a victim's browser. Types: reflected,
  stored, DOM-based. Defences: context-aware output encoding, CSP,
  HttpOnly cookies, sanitisation libraries.

CROSS-SITE REQUEST FORGERY (CSRF)
  A victim's browser is tricked into sending an authenticated request.
  Defences: anti-CSRF tokens, SameSite cookies, re-authentication for
  sensitive actions.

BROKEN ACCESS CONTROL / IDOR
  Users can access others' data by changing identifiers or bypassing checks.
  Defences: server-side authorisation on every request, deny by default,
  indirect references, tests for access rules.

BROKEN AUTHENTICATION AND SESSION MANAGEMENT
  Weak login, predictable sessions, no MFA, session fixation.
  Defences: MFA, strong password hashing, secure cookie flags, session
  rotation, rate limiting.

SECURITY MISCONFIGURATION
  Default accounts, verbose errors, open storage, unnecessary features.
  Defences: hardening baselines, automation, configuration scanning.

SERVER-SIDE REQUEST FORGERY (SSRF)
  Server is tricked into making requests to internal resources (cloud
  metadata, internal services). Defences: allow-lists, network egress
  restrictions, metadata service protections (IMDSv2).

INSECURE DESERIALISATION
  Untrusted serialised data leads to code execution or logic tampering.
  Defences: avoid native deserialisation of untrusted data, integrity
  checks, allow-listed types.

XML EXTERNAL ENTITY (XXE)
  XML parser loads attacker-defined external entities. Defences: disable
  DTDs/external entities, use safe parsers.

PATH TRAVERSAL / FILE INCLUSION
  Manipulating file paths to read or execute unintended files. Defences:
  canonicalise paths, allow-lists, avoid user-controlled paths.

RACE CONDITIONS (TOCTOU)
  Timing gaps allow state changes between check and use. Defences: atomic
  operations, locking, idempotent design.

USE OF VULNERABLE COMPONENTS
  Known flawed libraries (e.g. Log4Shell, Heartbleed, Apache Struts).
  Defences: SCA tools, SBOM, patching, dependency pinning.

CRYPTOGRAPHIC FAILURES
  Plaintext storage, weak ciphers, hard-coded keys, bad randomness.
  Defences: modern algorithms, key management, TLS everywhere (see Note 8).

SECRETS EXPOSURE
  API keys and passwords committed to code repositories. Defences: secret
  scanning, vaults, rotation, pre-commit hooks.

DENIAL OF SERVICE
  Resource exhaustion, algorithmic complexity, unbounded requests.
  Defences: rate limits, quotas, timeouts, resilient design.

6.5 VULNERABILITY IDENTIFIERS AND DATABASES

```
CVE (Common Vulnerabilities and Exposures): unique ID for publicly known
  vulnerabilities, format CVE-YEAR-NUMBER, run by MITRE; CNAs (CVE
  Numbering Authorities) assign IDs.
CWE (Common Weakness Enumeration): catalogue of weakness types (for example
  CWE-79 XSS, CWE-89 SQL injection, CWE-787 out-of-bounds write).
CAPEC: catalogue of attack patterns.
NVD (National Vulnerability Database): NIST enrichment with CVSS, CPE.
CPE: standard naming for products/versions.
CVSS: severity scoring (see below).
EPSS (Exploit Prediction Scoring System): probability a CVE will be
  exploited in the next 30 days.
KEV (CISA Known Exploited Vulnerabilities): list of CVEs confirmed as
  exploited in the wild - high priority for patching.
Other sources: vendor advisories (Microsoft Patch Tuesday, Oracle CPU),
  Exploit-DB, GitHub Advisories, OSV, CERT-In advisories, Vulners, VulDB.
Bug bounty/disclosure: HackerOne, Bugcrowd, vendor PSIRTs.
```

6.6 CVSS SCORING EXPLAINED

```
Base metric groups (v3.1):
  Exploitability: Attack Vector (Network/Adjacent/Local/Physical), Attack
    Complexity (Low/High), Privileges Required (None/Low/High), User
    Interaction (None/Required).
  Scope: Unchanged/Changed.
  Impact: Confidentiality, Integrity, Availability (None/Low/High).
Severity: Low 0.1-3.9, Medium 4.0-6.9, High 7.0-8.9, Critical 9.0-10.0.

Example vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H = 9.8 Critical
  (remote, easy, no privileges, no user interaction, full impact).

CVSS v4.0 adds Attack Requirements, Supplemental and Threat metrics and
better separation of base vs threat vs environmental scoring.

Limitations: CVSS measures severity, not risk. Context (internet exposure,
asset value, compensating controls, active exploitation) must be added.
```

6.7 VULNERABILITY MANAGEMENT LIFECYCLE

```
1. DISCOVER   : asset inventory; scanning (network, web, container, cloud,
                code); threat intel feeds; bug reports.
2. ASSESS     : validate, remove false positives, determine affected
                assets and exploitability.
3. PRIORITISE : CVSS + EPSS + KEV + asset criticality + exposure +
                compensating controls (risk-based vulnerability management).
4. REMEDIATE  : patch, upgrade, reconfigure, virtual patch (WAF/IPS rule),
                disable feature, segment, or mitigate.
5. VERIFY     : rescan and retest.
6. REPORT     : dashboards, SLAs, trends, executive summaries.
7. IMPROVE    : root-cause fixes (secure coding, baseline images, automation).

Sample SLAs: Critical/KEV: 24-72 hours to 7 days; High: 30 days; Medium: 60-90
days; Low: planned maintenance. Exceptions need documented risk acceptance.

Patch management best practices: test in staging, use rings (pilot then
broad), maintain emergency process, track EOL software, automate with
WSUS/SCCM/Intune/Ansible/Jamf, and keep rollback plans.
```

6.8 VULNERABILITY SCANNING

```
Types:
  - Network scans (hosts, ports, services).
  - Web application scans (DAST).
```

```
  - Authenticated vs unauthenticated scans.
  - Agent-based scans (endpoints; good for remote workers).
  - Container/image scans (Trivy, Grype, Clair).
  - Cloud posture management (CSPM).
  - Source code (SAST), dependency (SCA) and secrets scans.
  - Compliance/configuration scans (CIS benchmarks, STIG, OpenSCAP).
Tools: Nessus, Qualys VMDR, Rapid7 InsightVM, OpenVAS/Greenbone, Tenable.io,
  Nuclei, Nikto, OWASP ZAP, Burp, Acunetix, Trivy, Wazuh, Lynis.
Good practice: schedule regular scans, avoid peak hours for sensitive
  systems, tune scan policies, use credentials, scan new assets, and always
  have authorisation.
Challenges: false positives/negatives, scan impact on fragile systems,
  ephemeral cloud assets, shadow IT.
```

6.9 FAMOUS VULNERABILITIES AND LESSONS

```
Heartbleed (2014, OpenSSL): improper bounds check leaked server memory.
  Lesson: widely used libraries need funding, review and quick patching.
Shellshock (2014, Bash): environment variable parsing allowed command
  execution. Lesson: old, trusted components may hide critical flaws.
EternalBlue / MS17-010 (2017, SMBv1): exploited by WannaCry and NotPetya.
  Lesson: patch promptly and disable legacy protocols.
Equifax / Apache Struts (2017): unpatched web framework led to a major data
  breach. Lesson: asset inventory and patch SLAs matter.
Log4Shell (2021, Log4j): remote code execution through logging of untrusted
  input. Lesson: need an SBOM to find where components are used.
Spring4Shell, ProxyLogon/ProxyShell (Exchange), PrintNightmare, MOVEit,
  Citrix/Fortinet/Ivanti VPN edge-device flaws: attackers target internet-
  facing infrastructure quickly after disclosure.
Spectre/Meltdown (2018): hardware speculative execution flaws. Lesson:
  vulnerabilities exist below the software layer too.
SolarWinds (2020) supply chain attack and xz-utils backdoor attempt (2024):
  Lesson: trust in the build and maintainer chain must be verified.
```

6.10 ZERO-DAY AND EXPLOIT LIFECYCLE

```
Timeline: vulnerability introduced -> discovered (researcher or attacker) ->
disclosed or exploited -> vendor patch -> patch deployment -> residual
exploitation of unpatched systems.
Key terms: Window of exposure; proof-of-concept (PoC); exploit kit;
  weaponisation; N-day exploitation; virtual patching; mitigation guidance.
Defence against zero-days: defence in depth, least privilege, application
  allow-listing, exploit mitigations, EDR behavioural detection,
  segmentation, rapid emergency response and threat intelligence.
```

6.11 MITIGATION STRATEGIES (SUMMARY)

```
- Maintain full asset and software inventory (including SBOM).
- Patch with risk-based priorities and SLAs.
- Harden configurations using CIS/STIG baselines.
- Enforce least privilege and MFA.
- Segment networks; limit exposure of management interfaces.
- Use secure development practices and automated testing (see Note 7).
- Monitor with EDR, SIEM and threat intelligence.
- Test regularly: VAPT, red team, bug bounty.
- Prepare incident response plans for exploitation scenarios.
- Educate users and developers.
```

6.12 REPORTING A VULNERABILITY (DEFENDER OR RESEARCHER VIEW)

```
Good vulnerability report components:
  Title; affected product/version/URL; vulnerability type (CWE); severity
```

(CVSS vector); description; step-by-step reproduction; proof (screenshots, requests/responses, logs); impact; suggested fix; references; discovery date and disclosure timeline; contact details.
Keep proof non-destructive; do not access more data than needed.

6.13 EXAMPLE PRIORITISATION SCENARIO

Three findings:
A) Remote code execution in an internet-facing VPN appliance, CVSS 9.8, listed in KEV.
B) SQL injection in an internal HR tool, CVSS 8.1, accessible only to HR.
C) Missing HTTP security header on marketing website, CVSS 3.1.
Order: A first (exposed, actively exploited), B second (sensitive data, internal reach), C last (low risk, easy fix scheduled). A risk-based approach changes order compared with raw severity alone.

6.14 VULNERABILITY ASSESSMENT REPORT METRICS

- Total vulnerabilities by severity and by asset group.
- Mean time to detect (MTTD) and remediate (MTTR).
- SLA compliance percentage.
- Vulnerability age (days open) and backlog trend.
- Scan coverage percentage of assets.
- Percentage of KEV vulnerabilities remediated within target.
- Recurrence rate (same issue returning).
- Exceptions/risk acceptances count and expiry.

6.15 CAREER AND CERTIFICATIONS

Roles: Vulnerability Analyst, Vulnerability Management Engineer, Security Analyst, Application Security Engineer, Threat/Exposure Management Analyst, Vulnerability Researcher.
Certs: CompTIA Security+/CySA+/PenTest+, GIAC GCVM / GWAPT, CEH, Qualys/Tenable certifications, OSCP (for exploitation understanding), CISSP.

6.16 INTERVIEW QUESTIONS

Q: Difference between vulnerability, threat and exploit?
A: Vulnerability = weakness; threat = potential cause of harm; exploit = code or technique that takes advantage of the weakness.

Q: What is a zero-day?
A: A flaw unknown to the vendor with no patch available, possibly already exploited.

Q: What are CVE, CWE and CVSS?
A: CVE identifies a specific vulnerability; CWE classifies the weakness type; CVSS scores severity.

Q: How would you prioritise 5,000 findings?
A: Remove false positives, group by asset criticality and exposure, use CVSS with EPSS and KEV, fix internet-facing and actively exploited issues first, then automate patching for the rest.

Q: What is virtual patching?
A: Blocking exploitation through WAF/IPS rules or network controls before the actual software patch can be applied.

Q: Why is authenticated scanning better?
A: It sees installed patches, configuration and local vulnerabilities, reducing false positives and improving accuracy.

Q: What is an SBOM?
A: A Software Bill of Materials listing components and versions in an

application, used to find vulnerable dependencies quickly.

6.17 SUMMARY OF NOTE 6

Vulnerabilities arise from code, design, configuration, process and human weaknesses. Use common identifiers (CVE, CWE, CVSS), apply risk-based prioritisation (EPSS, KEV, asset value), follow a disciplined lifecycle (discover, assess, prioritise, remediate, verify, report) and fix root causes through secure development and strong configuration management.